



Instituto Politécnico Nacional
Escuela Superior de Cómputo
Ingeniería en Sistemas Computacionales



Gobierno de TI

**Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de
infraestructuras críticas)**

Alumnos:

Carol Monserrat Chávez Hernández

Alfredo Bautista Ríos

Diego Alejandro Moreno Martínez

Grupo: 7CV2

Profesora: Palacios Solano Rocío

Fecha de entrega: 05/01/2026

Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de infraestructuras críticas)

Se evalúan riesgos considerando el impacto a Confidencialidad (C), Integridad (I) y Disponibilidad (D), así como la criticidad de la infraestructura que soporta el servicio. La valoración es cualitativa (Alta/Media/Baja) y permite priorizar controles.

Activo	C	I	D	Justificación (resumen)	Controles recomendados
Plataformas SAST/DAST	Media	Alta	Media	Definen hallazgos y calidad; caída afecta liberaciones.	Alta disponibilidad lógica, respaldos de configuración, control de acceso.
SIEM y logs centralizados	Alta	Alta	Alta	Datos sensibles y forenses; indisponibilidad afecta detección.	Retención cifrada, RBAC, redundancia y monitoreo.
WAF/Firewall perimetral	Media	Alta	Alta	Control de perímetro; falla expone aplicaciones.	HA/cluster, cambios controlados, backups de reglas.
Plataforma ITSM	Media	Media	Alta	Trazabilidad de remediación y SLA.	Backups diarios, roles, continuidad del proveedor.
Entorno de staging	Media	Media	Media	Ambiente de pruebas; posible exposición si se configura mal.	Segregación de redes, llaves rotadas, hardening.

Infraestructuras críticas

Infraestructura/s servicio	Criticidad	Dependencias	Impacto principal	Acciones de protección
SIEM y almacenamiento de logs	Crítica	Servidor, red, almacenamiento, credenciales	Detección y forense se degradan; riesgo de no cumplimiento.	Redundancia, cifrado, monitoreo, pruebas de restauración.
WAF/Firewall perimetral	Crítica	Energía, red, gestión de cambios	Aumento inmediato de exposición y ataques.	HA, backups, ventanas de cambio, revisión de reglas.
CI/CD y repositorios	Alta	Herramientas DevOps, credenciales	Controles no se ejecutan; liberaciones sin evaluación.	Integridad de pipelines, MFA, segregación y auditoría.
Service Desk / ITSM	Alta	Proveedor/infra	Se pierde control y trazabilidad de remediación.	Plan alternativo de registro, backups y exportaciones

				periódicas.
--	--	--	--	-------------